



**NANYANG
TECHNOLOGICAL
UNIVERSITY**
SINGAPORE

NTU Academy for Professional
and Continuing Education

Hacking AI: LLM Vulnerabilities

Hacking AI: how LLMs are attacked – and why one flaw explains all of it

Module 5

Created by :

Swarup Biswas



It followed instructions perfectly. That was the attack.

In 2026 Microsoft patched a prompt-injection flaw in Copilot. The data leaked anyway.

Source: *ShareLeak*, CVE-2026-21520

An LLM cannot tell instructions from data

Everything in the context window — your prompt, a document, a web page, a tool — arrives as the same stream of tokens. There is no return address.

Source: OWASP LLM01, 2023 & 2025

Prompt injection does not hack the model

It uses the model exactly as designed. The attacker simply becomes the instruction-giver.

Every attack is four choices

$$\textit{Attack} = \textit{Intent} \times \textit{Input} \times \textit{Technique} \times \textit{Evasion}$$

The four pillars

Pillar	The question it answers
Intent	What is the attacker trying to achieve?
Input	Where does the payload enter?
Technique	How is the model manipulated?
Evasion	How is it hidden from filters?

Source: PITAX v1.6.1 – 172 nodes across these four pillars

Now read any headline with it

The ShareLeak attack, decomposed

Intent — exfiltrate SharePoint data

Input — an untrusted form field (indirect)

Technique — injected instruction to the agent

Evasion — routed out through a trusted channel

Why jailbreaks always work

Competing objectives — trained to be helpful AND harmless; persuasion tips the balance

Mismatched generalisation — safety training covers less ground than the model's abilities

Source: Wei, Haghtalab & Steinhardt, NeurIPS 2023

Techniques — how the model is steered

Direct request — just ask; still works `PIT-T-60`

Narrative injection — wrap it in a story or role `PIT-T-08`

Crescendo — benign, then worse, across turns `PIT-T-29`

Many-shot — flood the context with fake compliant examples `PIT-T-30`

Policy puppetry — present it as an official policy `PIT-T-34`

Tool poisoning — hide it in an agent's tool description `PIT-T-42`

Evocations — how it hides from filters

Base64 / layered encoding — filters scan for keywords; encoding slips past `PIT-E-07`

Homoglyphs & invisible text — looks normal to a human reviewer `PIT-E-20`

Adversarial poetry & rare languages — routes around thin safety coverage `PIT-E-52`

The attack surface is everything the model reads

Direct input needs a chat box. Indirect input hides in a document, email, web page, or tool the model ingests for you.

Source: PITAX Inputs – indirect is the dangerous class

Try it yourself — beat a real AI

- Open **gandalf.lakera.ai** (extract a secret) or **promptairlines.com** (win a free flight)
- No login, any browser or phone. See how far you get
- For each win, name it: which Intent, Input, Technique, Evasion?
- Debrief: which control **outside the model** would have stopped you?

Microsoft patched it. It leaked anyway.

ShareLeak (CVE-2026-21520): patched Jan 2026. Researchers exfiltrated the data regardless.

You cannot patch your way out of an architectural flaw.

The same attack, everywhere

Incident	What happened
SearchLeak (CVE-2026-42824)	Crafted URL → M365 Copilot leaks via Bing, CVSS 9.1
EchoLeak (CVE-2025-32711)	Zero-click email; no user action needed
Slack AI (2024)	Post in a public channel → private-channel data leaks
ServiceNow (2025)	Low-privilege agent talks a senior agent into exporting a file

Five documents poisoned a corpus of millions

A RAG system returned the attacker's false answer **90%** of the time — confident, citation-backed, no hallucination signal.

Source: PoisonedRAG, Zou et al., USENIX Security 2025

Agents change the class of harm

A text-only LLM can only talk. An LLM that sends email, queries databases, and calls APIs can act.

Blast radius scales with the agent's permissions — not the attacker's skill.

The lethal trifecta

Privileged access — acts with your credentials

Untrusted input — reads docs, emails, tool descriptions

Autonomous action — no human approval per step

*Meta's Rule of Two: an agent should have no more than **two** of these at once.*

The posture is resilience, not prevention

Validate inputs AND outputs — normalise before filtering

Least privilege — short-lived, separate credentials

Controls **outside** the model — ACLs and identity, not "please don't" in a prompt

Treat all retrieved content as untrusted

Real human veto before irreversible actions

Source: The Attacker Moves Second, OpenAI/Anthropic/Google DeepMind, 2025

The compliance floor

Framework	What to know
EU AI Act	Binding; high-risk penalty up to €15M / 3% turnover. Most Annex III obligations deferred to Dec 2027 (June 2026 Omnibus)
NIST AI RMF	Voluntary — Govern, Map, Measure, Manage
ISO/IEC 42001	Certifiable AI management system

The vulnerability is architectural. The defence is layered.

The posture is resilience — not the false promise of prevention.

Version Management

Month/Year	Version	Changes
May 2026	0.0	New Module Design
July 2026	1.0	Refreshed & Updated Content